Module 1 - Review Questions

1. What is the difference between a threat agent and a threat source?

- Threat source is a category of objects/people that pose a danger to an asset. (Ex. Acts of trespass or espionage)
- The threat agent is the specific instance of the threat source object/person. (Ex. External professional hacker)

2. What is the difference between vulnerability and exposure?

Vulnerability is a potential weakness in an asset or its defensive control systems (Ex, a flaw in a software package or an unprotected system port). It becomes an exposure when it is known to an attacker.

3. What is a loss in the context of information security?

An asset being damaged, unauthorized disclosure or modificatıon, or denied use. (Ex. Organization information is being stolen.

4. What type of security was dominant in the early years of computing?

Physical security was dominant in the early years of computing, with a focus on protecting physical locations and assets from threats.

5. What are the three components of the C.I.A. triad? What are they used for?

Confidentiality, Integrity, Availability. It is an industry standard describing the critical characteristics of information, data, and services that are important to protect.

6. If the C.I.A. triad is incomplete, why is it so commonly used in security?

It addresses the fundamental concerns of information security: confidentiality, integrity, and availability.

7. Describe the critical characteristics of information. How are they used in the study of computer security?

CIA + Accuracy, Authenticity, Utility, and Possession. In computer security, they identify what needs protection and guide how to keep information safe and reliable. Moreover, they serve as guidelines for assessing risks, creating policies, and implementing controls to ensure that information is both protected and usable.

8. Identify the six components of an information system. Which are most directly affected by the study of computer security? What are the most commonly associated with its study?

Software, hardware, data, people, procedures, networks. Mostly affected are the data. Commonly associated with people and procedures, because human error and weak policies often cause breaches.

9. What is the McCumber Cube, and what purpose does it serve?

The McCumber Cube is a model used to evaluate information security programs. It represents the relationship between three dimensions:

- Security goals: CIA (Confidentiality, Integrity, Availability)
- Information states: Policy / Education / Technology
- Security measures: Storage / Processing / Transmission.

The purpose is to show that adequate security requires addressing all three dimensions simultaneously.

10. Which paper is the foundation of all subsequent studies of computer security?

RAND Report R-609. It systematically analyzed computer security risks, introduced the need for formal controls, addressed both technical and human threats, and laid the foundation for later research and standards.

11. Why is the top-down approach to information security superior to the bottom-up approach?

The top-down approach to information security is superior because it enjoys strong support from upper management, has dedicated funding, follows a clear planning and implementation process, and can shape organizational culture. In contrast, the bottom-up approach often lacks broad support and long-term sustainability within the organization.

12. Describe the need for balance between information security and access to information in information systems.

Security should be considered a balance between protection and availability because if security is too strict, legitimate users may struggle to access needed information and if it is too lenient, the system becomes vulnerable to threats

13. How can the practice of information security be described as both an art and a science? How does the view of security as a social science influence its practice?

The practice of information security can be described as an art because there's no hard rules or manual for a complete security solution and a science because it is technology-related, developed by scientists & engineers.

Since security ultimately depends on how people use or misuse systems, by understanding these behaviors, administrators can reduce risks, design more practical policies, and build security measures that users are more likely to accept and support.

14. Who is ultimately responsible for the security of information in the organization?

CISO, Chief Information Security Officer

15. What is the relationship between the MULTICS project and the early development of computer security?

The MULTICS project directly influenced the early development of computer security because it was the first operating system to have security integrated into its core design. Its

innovative approach to secure time-sharing shaped later research and practices in information security.

16. How has computer security evolved into modern information security?

Started in WW2, breaking into the German code Enigma. Then ARPANet, now the Internet, became popular and required modern IS. Initially, physical and technical security, but it has evolved to include data, networks, and people.

17. What was important about RAND Report R-609?

Started the study of Computer Security and identified the role of management and policy issues in it.

18. Who decides how and when data in an organization will be used or controlled? Who is responsible for seeing that these decisions are carried out?

The Data owners are responsible for the security and use of the set of information the organization has. On the other hand, the Data Custodıans are the ones that implement and enforce the policies and procedures established by the data owners.

19. Who should lead a security team? Should the approach to security be more managerial or technical?

A project manager should lead the security team with managerial skills and security awareness. The managerial approach is more critical because it ensures upper management support and funding.

20. Besides the champion and team leader, who should serve on an information security project team?

Besides the champion and team leader, the team should include Security Policy Developers, Risk assessment specialists, Security Professionals, System administrators, and End users.